

Digitale Gesundheitsplattformen und APIs

Architekturansätze für skalierbare e-Health Vernetzung am Beispiel der Telematikinfrastuktur

Dr. Fabian Franzelin

2026-09-24

Schön, dass ich heute bei Ihnen sein darf — ich freue mich auf diese Probevorlesung.

Was ich heute mitbringe:

- Mich, einen **Softwarearchitekten**
- Einen **Leitfall**
- Vier **Architekturprinzipien**
- Einen **Architekturansatz** zur **Skalierbarkeit** von e-Health Diensten
- Einen Einblick in die **Telematikinfrastruktur 2.0**

Was Sie mitbringen:

- Sich, motivierte **Studierende**
- Info 1/2: UML-Sequenzdiagramme, HTTP, JSON
- Formale Methoden: Kryptographie-Grundlagen (RSA)
- Medizininformatik: Krankenhausinformationssysteme, PVS, Standards
- Neugier auf: Cloud, Container, Zero Trust — die schauen wir uns gemeinsam an

Und los geht's mit einer Schlagzeile...

"Konnte bisher noch nie gehackt werden." Karl Lauterbach

- **Als CCC:** Wie hacke ich das System? ¹
- **Als Patient:** Sind meine Daten sicher?
- **Als angehende Informatiker:** Wie baut man so etwas *richtig*?
- **Als gematik:** Wie reagiert man auf so einen Hack? → TI 2.0
- **Als Vortragender heute:** Zeigen wir das an einem Alltagsfall — der elektronischen Arbeitsunfähigkeitsbescheinigung (eAU).

¹Martin Tschirsich, Bianca Kastl, „Konnte bisher noch nie gehackt werden!': Die elektronische Patientenakte kommt — jetzt für alle!“, 38C3, Chaos Computer Club, 27.12.2024. [Link](#)

- Der Angriff nutzte keine Zero-Day-Lücke — er nutzte **Vertrauen auf Netz- und Hardware-Ebene** statt auf Ebene von Identität und Kontext.
- Die gematik reagiert mit **TI 2.0**: offene Standards, Zero Trust, Cloud-Betrieb.
- Bevor wir uns die Prinzipien anschauen: *wie sieht so ein vernetzter Versorgungsprozess überhaupt aus?*

Die elektronische Arbeitsunfähigkeitsbescheinigung

Was ist die eAU?

Eine eAU ist kein einzelnes Dokument, sondern ein **verteilter Prozess**:

- Praxissoftware erfasst und signiert die Bescheinigung.
- Die Krankenkasse erhält die für sie bestimmten Daten.²
- Der Arbeitgeber ruft die für ihn erforderlichen Daten ab.
- Jede Rolle erhält nur die Daten, die sie für ihren Zweck benötigt.

Ein verteilter Prozess ruft nach einem Werkzeug, das Sie kennen:

dem **Sequenzdiagramm**.

Phase 1: Datenerhebung & Kassenmeldung

- Identität vor Zugriff (Arzt)
- Heterogene Primärsysteme (PVS, VZD, KIM)
- Ortsunabhängiger Zugriff

Architekturprinzipien

Nehmen wir die Beobachtungen aus unserem Leitfall:

Beobachtung	Qualitätsmerkmal	Architekturprinzip
Identität vor Zugriff	Datensicherheit	Zero Trust
Asynchrone Übermittlung	Verfügbarkeit	Hardware-Abstraktion & Cloud
Zugriff ortsunabhängig	Mobilität	Digitale Identitäten
Viele Organisationen/Systeme	Interoperabilität	Offene Standards & Open Source

Prinzip 1: Zero Trust

Zero Trust beschreibt ein aus dem "Assume Breach"-Ansatz entwickeltes Architekturdesign-Paradigma, welches im Kern auf dem Prinzip der minimalen Rechte aller Entitäten in der Gesamtinfrastruktur basiert.³

Verfügbarkeit & Skalierbarkeit

Schauen wir uns die eAU wieder an...

Im Mittel bei einem Zugriff pro eAU auf einen Arbeitstag (8h)⁵

$$\frac{496 \text{ Mio. Fälle seit 01.08.2021}}{5.1 \text{ Jahre}} \approx 97 \text{ Mio. Fälle/Jahr} \approx 265 \text{ Tsd. Fälle/Tag} \approx 9 \text{ Fälle/Sekunde}$$

Schranken für die Auslegungslast (eAU)

Auslegung nach oberer Schranke, Kostenoptimierung nach unterer.

Kennzahl	Wert [Zugriffe/s]	Herleitung	
Untere Schranke (Tagesmittel)	~9	265 Tsd. Fälle / 8 h	
Peak-Faktor Wochentag/Tageszeit	×2	Montag/Vormittag	10
Peak-Faktor Infektuelle	×5-10	Grippe-/COVID-Season	

Zusammenfassung

1. **Architekturansätze** leiten sich von den Anforderungen und den Qualitätsmerkmalen ab
2. **Skalierbar**: Elastisches System das mit Grundlast und Spitzen umgehen kann; Entkopplung von Hardware und Dienst.
3. **Vernetzung**: offenes Netz mit Zero-Trust Ansatz
4. **Telematikinfrastruktur**: Alle vorgestellten Konzepte basieren auf der Version 2.0

War ich froh zu lesen, dass TI2.0 aktuell ausgerollt wird

TI vs. Internet — ein Vergleich

Dimension	Internet	TI 1.x
Grundannahme	Offenes Netz, "assume hostile"	Geschlossenes Netz,
Zugang	Jeder mit IP-Adresse	Nur über zugelassene
Adressierung	DNS, IP, URL	KIM-Adressen, VPN-
Identität	Optional (TLS-Zertifikat, Login je Dienst)	An Karte/Konnektor
Sicherheit	Ende-zu-Ende auf Anwendungsebene (TLS, OAuth)	Netzwerksegmentierung
Governance	IETF/W3C, dezentral, konsensbasiert	gematik, staatlich re
Standards	HTTP, TLS, JSON, OAuth	Eigene TI-Fachdienst
Skalierung	Horizontal, global, CDN	Begrenzt durch Konn
Ausfallverhalten	Best effort, redundante Pfade	Einzelner Konnektor
Datenmodell	Anwendungsspezifisch	FHIR/CDA + Spezif